

Plan de Administración y Mejora de la Red

Documento de trabajo basado en los tres escaneos de auditoría (172.16.68.0/24, 172.16.69.0/24 y 192.168.60.0/24). Pensado como guía paso a paso para ordenar y profesionalizar la administración de los equipos, priorizando lo de mayor impacto y menor esfuerzo primero.

1. Resumen ejecutivo

La red está dividida en tres segmentos con alrededor de **110 dispositivos activos** en total. La base es buena: ya existe segmentación por subredes, un Controlador de Dominio, una consola de antivirus (ESET PROTECT), un controlador de red (UniFi) y gestión fuera de banda de servidor (Dell iDRAC).

La gran mayoría de los 182 hallazgos combinados **no son riesgos graves**: son el ruido normal de una red Windows (puertos SMB/RPC en las estaciones de dominio) y certificados autofirmados que traen de fábrica los appliances. Lo realmente accionable se concentra en unos pocos puntos.

Las prioridades de administración, en orden, son:

- 1 Inventario y nombres (hoy todo aparece "sin nombre").
 - 2 Cerrar la segmentación con una VLAN de gestión.
 - 3 Aprovechar al máximo las consolas centrales que ya se tienen.
 - 4 Certificados internos (PKI) para dejar de convivir con autofirmados.
 - 5 Gestión de parches con panel central.
 - 6 Monitoreo y mantenimiento continuo.
-

2. Inventario actual (lo que revelan los escaneos)

Red 172.16.68.0/24 — LAN principal (usuarios + servicios)

79 equipos activos. Contiene:

- El **gateway/router** (172.16.68.1): SSH y HTTP publicados.
- El **controlador UniFi** (172.16.68.51): certificados `unifi.local` / `Ubiquiti` en 443 y 8443.
- El **NAS QNAP** (172.16.68.76): SMB (ya con SMBv1 deshabilitado).
- Impresoras / equipos embebidos (172.16.68.53, .55: banner "webserver").
- Servidores Linux con aplicaciones (172.16.68.153, .155: puerto 8080).
- Alrededor de **50 estaciones de trabajo Windows** con solo 135 (RPC) y 445 (SMB) abiertos.

Red 172.16.69.0/24 — Equipos de red

28 equipos activos. Son en su mayoría **puntos de acceso y switches Ubiquiti** (SSH Dropbear, prefijo MAC 78:45:58 = Ubiquiti). SSH publicado en cada uno.

Red 192.168.60.0/24 — Servidores y gestión

3 equipos activos:

- El **Controlador de Dominio** (192.168.60.12): DNS, LDAPS, RDP, WinRM, y la consola **ESET PROTECT** (certificado propio en 443).
- Un **servidor Dell con iDRAC** (192.168.60.14): gestión fuera de banda + Apache.
- El router del segmento (192.168.60.1).

Patrón de los hallazgos

- La mayor parte del volumen son dos hallazgos repetidos en decenas de PCs ("SMB expuesto" + "RPC/WMI expuesto"), que son inherentes a una estación unida a dominio y no un problema en sí.
- El segundo patrón son **certificados autofirmados** en cada appliance (UniFi, ESET, iDRAC, QNAP).
- Lo de prioridad real: RDP publicado en el DC, y accesos de administración (SSH de APs, iDRAC, consolas) alcanzables desde la red de usuarios.

3. Plan paso a paso

Fase 1 — Inventario y nombres (la base)

Objetivo: que cada IP tenga un nombre y un responsable. Hoy todo aparece "sin nombre" porque el DNS inverso no está configurado, y sin nombres administrar 110 equipos es a ciegas.

Pasos:

- 1 En el Controlador de Dominio (192.168.60.12), abrir la consola de DNS (`dnsmgmt.msc`).
- 2 Crear las **zonas de búsqueda inversa** para cada subred: `172.16.68.x`, `172.16.69.x` y `192.168.60.x`.
- 3 Habilitar que los registros PTR se creen/actualicen automáticamente junto con los registros A (opción "Actualizar registro de puntero asociado" en las propiedades de la zona directa).
- 4 Para los equipos que no son de dominio (appliances, impresoras, APs), crear los registros A + PTR a mano con un nombre descriptivo (`nas-qnap`, `ap-piso2-01`, `idrac-srv1`, etc.).
- 5 Armar una **planilla de inventario (CMDB)** con estas columnas: IP, MAC, nombre, tipo (PC / servidor / AP / impresora / NAS), sistema operativo, ubicación física y responsable. El reporte JSON de la auditoría sirve como punto de partida (ya trae IP + MAC + puertos).
- 6 Usar el prefijo del MAC (OUI) para identificar fabricantes cuando el nombre no sea obvio (ej. 78:45:58 = Ubiquiti).

Cómo verificar: volver a correr el escáner; los equipos deberían aparecer ahora con nombre en la columna "Hostname".

Fase 2 — Segmentación y VLAN de gestión

Objetivo: que los accesos de administración (RDP, SSH de red, iDRAC, consolas) NO sean alcanzables desde la red de usuarios. Hoy el RDP del DC y el SSH de los APs se ven desde la LAN común.

Pasos:

- 1 Definir (o confirmar) una **VLAN/subred de gestión** dedicada al equipo de IT. La red 192.168.60.0/24 ya cumple parcialmente ese rol.

2 En el firewall / router entre segmentos, crear reglas que permitan el acceso a puertos de administración **solo desde la subred de gestión**:

- RDP (3389) → solo hacia servidores desde IT.
- SSH (22) de los equipos Ubiquiti → solo desde IT.
- iDRAC (443/623) del servidor Dell → solo desde IT.
- Consola UniFi (8443) y WinRM (5985/5986) → solo desde IT.

1 Para los equipos Windows de dominio, aplicar el GPO **SEC-14** (incluido en `create_gpos.ps1`) para restringir RDP a la subred de gestión:

```
.\create_gpos.ps1 -PilotOU "OU=Piloto,DC=tu,DC=dominio" -RdpManagementSubnet "192.168.60.0/24"
```

1 Probar primero en una OU piloto de 2-3 equipos, validar acceso normal, y recién después expandir.

Cómo verificar: desde una PC de usuario común, intentar `mstsc` al DC o SSH a un AP: debe fallar. Desde un equipo de IT, debe funcionar.

Fase 3 — Aprovechar la gestión centralizada existente

Objetivo: exprimir las consolas que ya se tienen, en vez de administrar equipo por equipo. Este es el mayor multiplicador de eficiencia.

3.1 ESET PROTECT (consola de endpoints, en el DC)

- 1 Entrar a la consola web de ESET PROTECT.
- 2 Verificar que **los ~50 equipos Windows** (y los que correspondan) aparezcan como "gestionados" y reportando.
- 3 Identificar los equipos SIN el agente instalado y desplegarlo (por GPO o instalador remoto).
- 4 Usar los paneles de ESET para: estado de antivirus, equipos desactualizados y detecciones. Programar un reporte semanal.

3.2 Active Directory y GPO (en el DC)

- 1 Confirmar que todas las estaciones estén unidas al dominio y en la OU correcta.
- 2 Aplicar por GPO el endurecimiento de bajo riesgo (los GPO de `create_gpos.ps1`: Telnet, LLMNR, Defender, bloqueo de puertos de acceso remoto, Windows Update), primero en la OU piloto.
- 3 Documentar qué GPO afecta a qué OU.

3.3 Controlador UniFi (equipos de red)

- 1 Verificar que todos los APs/switches Ubiquiti estén adoptados en el controlador.
- 2 Mantener el firmware al día desde ahí (no equipo por equipo).
- 3 Gestionar VLANs y SSIDs de forma central.

3.4 iDRAC (servidor Dell)

- 1 Confirmar acceso a la consola iDRAC del servidor (192.168.60.14).
- 2 Usarla para encendido/apagado, consola remota y actualización de firmware sin ir físicamente.

- 3 Cambiar la contraseña por defecto del iDRAC si aún no se hizo, y restringir su acceso a la subred de gestión (Fase 2).

Cómo verificar: cada consola debería mostrar el 100% de sus equipos correspondientes reportando/adoptados.

Fase 4 — Certificados internos (PKI)

Objetivo: dejar de convivir con certificados autofirmados en cada appliance (UniFi, ESET, iDRAC, QNAP), que generan hallazgos y advertencias de navegador constantes.

Pasos:

- 1 Instalar el rol **Servicios de certificados de Active Directory (AD CS)** en un servidor (idealmente NO el DC principal, pero es válido en entornos chicos).
- 2 Configurar una **CA raíz interna**.
- 3 Distribuir el certificado de la CA a todos los equipos de dominio por GPO (para que confíen en los certificados internos automáticamente).
- 4 Emitir certificados de la CA interna a los appliances que lo permitan (UniFi, ESET, iDRAC, QNAP suelen aceptar importar un certificado).
- 5 Para los que no se puedan, documentarlos como "autofirmado aceptado - solo interno" para que no figuren como sorpresa en la próxima auditoría.

Cómo verificar: acceder a las consolas por HTTPS desde un equipo de dominio: no deberían aparecer advertencias de certificado.

Fase 5 — Gestión de parches

Objetivo: tener visibilidad central de qué equipos están atrasados en parches del sistema operativo.

Pasos:

- 1 Correr el script `patch_audit.ps1` contra el DC y las estaciones para una foto inmediata:

```
.\patch_audit.ps1 -File equipos.txt
```
- 1 Priorizar los equipos que aparezcan en rojo (actualizaciones críticas pendientes) o inalcanzables.
- 2 A mediano plazo, montar **WSUS** (gratis) o usar **Intune / Windows Update for Business** para tener un panel de cumplimiento permanente y aprobar parches de forma central.
- 3 Para los appliances (QNAP, UniFi, iDRAC), revisar y programar sus actualizaciones de firmware desde sus propias consolas.

Cómo verificar: el reporte de `patch_audit.ps1` debería mostrar cada vez menos equipos con pendientes críticas.

Fase 6 — Monitoreo y mantenimiento continuo

Objetivo: que esto no sea una foto de una vez, sino un proceso.

Pasos:

- 1 Definir una **rutina mensual**: correr el escáner de auditoría, el `patch_audit.ps1`, y revisar los paneles de ESET y UniFi.

- 2 Mantener la planilla de inventario actualizada (equipos nuevos, bajas).
 - 3 Guardar los reportes con fecha para poder mostrar la evolución (menos hallazgos mes a mes es tu mejor evidencia de trabajo).
 - 4 Documentar cada cambio importante (qué GPO se aplicó, qué se restringió, qué se parcheó) en una bitácora simple.
-

4. Checklist priorizada (para arrancar ya)

Prioridad alta (esta semana):

- 1 Configurar DNS inverso (PTR) en el DC para las tres subredes.
- 2 Empezar la planilla de inventario desde el reporte de auditoría.
- 3 Verificar en ESET PROTECT qué equipos NO están reportando.
- 4 Cambiar contraseñas por defecto que sigan puestas (iDRAC, appliances).

Prioridad media (este mes):

- 1 Restringir RDP / SSH de red / iDRAC / consolas a la subred de gestión.
- 2 Aplicar los GPO de hardening en la OU piloto y validar.
- 3 Correr `patch_audit.ps1` y atacar las pendientes críticas.

Prioridad de fondo (siguiente trimestre):

- 1 Montar AD CS y reemplazar certificados autofirmados.
 - 2 Montar WSUS o Intune para gestión central de parches.
 - 3 Formalizar la rutina mensual de auditoría + inventario.
-

5. Anexo — comandos y referencias útiles

- Escaneo de auditoría (inventario + hallazgos):

```
IPSecurityAuditTool.exe --targets 172.16.68.0/24
```

- Estado de parches de la flota:

```
.\patch_audit.ps1 -File equipos.txt
```

- GPO de hardening (con restricción de RDP):

```
.\create_gpos.ps1 -PilotOU "OU=Piloto,DC=tu,DC=dominio" -RdpManagementSubnet "192.168.60.0/24"
```

- Endurecimiento local de un equipo Windows puntual:

```
IPHardeningTool.exe
```

- Verificar qué está usando un servidor antes de endurecerlo:

`.\preflight_check.ps1`

- Límites de cobertura (lo que la suite NO cierra, para gestionarlo aparte): ver el documento [COBERTURA_LIMITES.md](#).

Documento de trabajo interno. Ajustar nombres de OU/ dominio/subredes a los valores reales del entorno antes de ejecutar los comandos.